

# 【中间件安全】WebSphere安全加固规范 - 微信公众号Bypass

## 1. 适用情况

适用于使用WebSphere进行部署的Web网站。

## 2. 技能要求

熟悉WebSphere安装部署，熟悉WebSphere常见漏洞利用方式，并能针对站点使用WebSphere进行安全加固。

## 3. 前置条件

根据站点开放端口，进程ID，确认站点采用WebSphere进行部署；

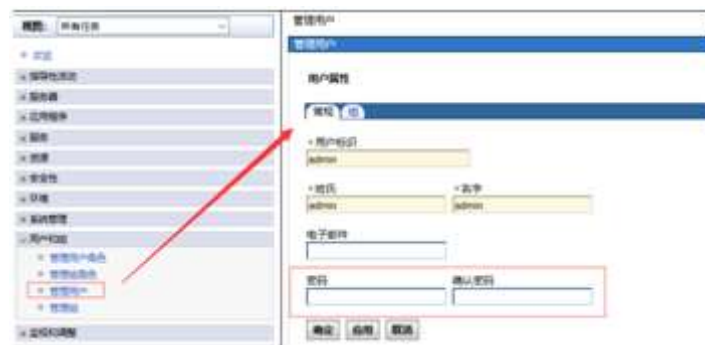
找到WebSphere站点位置

## 4. 详细操作

### 4.1 账号安全

参考配置操作：

1、修改用户口令，口令长度至少 8 位，并包括数字、小写字母、大写字母和特殊符号四类中至少 3 类。



### 4.2 日志配置

参考配置操作：

1、在导航窗格中，单击服务器>应用程序服务器-->单击您要

使用的服务器的名称（server1）-->在“故障诊断”下面，单击NCSA 访问和 HTTP 错误记录 -->在常规属性中，勾选在服务器启动时启用记录服务。



2、重启服务生效。日志文件地址：

`${WebSphere}\AppServer\profiles\AppSrv01\logs\server1\http_access.log`

## 4.3 最佳操作实践

### 4.3.1 禁止目录浏览

参考配置操作：

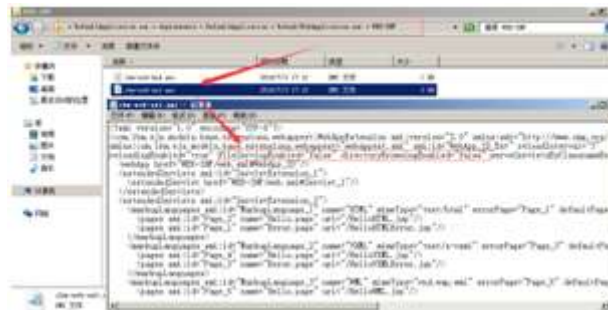
用文本编辑器打开

`$WAS_HOME/<profilepath>/config/cells/<hostname>/applications/`

`<yourapplication>.ear/<yourapplication>.war/WEB-INF/ibm-web-ext.xmi`

设置`fileServingEnabled="false"`

设置`directoryBrowsingEnabled="false"`



### 4.3.2 错误页面处理

参考配置操作：

1、用文本编辑器打开

`${WebSphere}/<profilepath>/config/cells/<hostname>/applications/`

`<yourapplication>.ear/<yourapplication>.war/WEB-INF/ibm-web-ext.xmi`

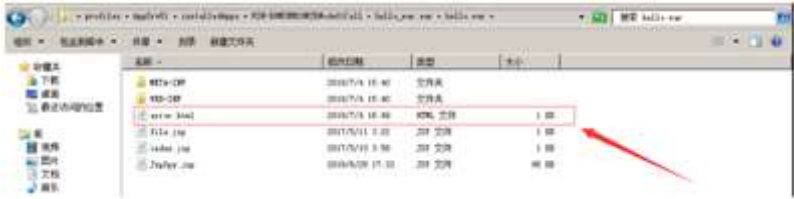
设置`defaultErrorPage=" /error.html"`



2、在站点根目录

`${WebSphere}\AppServer\profiles\AppSrv01\installedApps \<hostname>\<yourapplication>.ear\  
<yourapplication>.war/`

新建error.html文件



4.3.3 安全备份

参考配置操作：

每周备份一次 config 和 properties 目录，至少每月备份一次 WebSphere 全目录,生产环境配置更改前必须先备份。

(1) 以 WAS 身份，执行：

`#$WAS_HOME/bin/backupConfig.sh`

(2)如以 root 身份，最好运行：

`#tar cvf $WAS_HOME/profiles/default/config`

`#tar cvf $WAS_HOME/profiles/default/properties`

4.3.4 启用会话安全性

参考配置操作：

1、在导航窗格中，单击服务器>应用程序服务器-->单击您要

使用的服务器的名称（server1） -->单击会话管理 -->在常规属性中，勾选覆盖会话管理和安全性集成。





## 4.4 风险操作项

### 4.4.1 删除默认程序

参考配置操作：

以管理员身份打开管理控制台,执行：

- 1. 点击“ 应用程序” -->“ 企业应用程序”
- 2. 选中例子程序, 然后点击“ 卸载” 按钮, 卸载“

DefaultApplication” 、 “PlantsByWebSphere ”、  
“SamplesGallery” 、 “ivtApp” 等子程序

- 3. 点击保存到主配置, 自动删除

\${WebSphere}\AppServer\profiles\AppSrv01\installedApps目录下源码。



### 4.4.2 补丁更新

查看版本信息：

cd \$WAS\_HOME/bin

/versionInfo.sh

查找最新补丁及版本并进行安装

**最后**

欢迎关注个人微信公众号：Bypass--，每周原创一篇技术干货。



posted @ 2018-12-24 11:03 [Bypass](#) 阅读(...) 评论(...) [编辑](#) [收藏](#)